

Surname(s) / APELLIDOS	Name / NOMBRE

Ejercicio 1 [7 puntos]

Las Ilustración 1 y la hoja adjunta muestran una cadena de certificados y los contenidos de cada uno de los mismos. Esta cadena de certificados ha sido devuelta al iniciar una conexión a la web www.apple.com. Basándote en la cadena de certificados mostrada y el contenido de cada certificado responde a las siguientes preguntas:

Ilustración 1: Cadena de certificados*Ilustración 2: Certificados pertenecientes a la cadena*

- a) Escribe el nombre común del dominio representado por el certificado devuelto por el servidor web. [0,25 puntos]
www.apple.com
- b) Escribe el número de serie del certificado anterior. [0,25 puntos]
C0806592 o 1A 52....
- c) ¿Qué empresa ha emitido ese certificado? [0,25 puntos]
Apple Inc
- d) Describe el tipo de clave pública que incluye el certificado referido en a) [0,25 puntos]
Incluye una clave pública RSA de 2048 bits con exponente 65537
- e) Explica de forma breve el cometido de la clave pública y el exponente del certificado devuelto por el servidor web. [1,5 puntos]
Esa clave pública se utiliza para establecer una clave de sesión que se utilizará para cifrar, mediante un cifrador simétrico tipo AES, la conexión al servidor. En particular la clave pública es la n de la exponenciación y el exponente es a lo que se eleva lo que se quiere cifrar para establecer la clave de sesión.
- f) ¿Con qué algoritmo se ha firmado ese certificado? [0,25 puntos]
Se ha firmado mediante RSA con un hash SHA256
- g) Si el certificado referido en a) hubiese sido firmado mediante DSA, qué tamaño tendría su firma? [0,5 puntos]
La firma serían 512 bits ya que r y s son del tamaño del hash utilizado

- h) Escribe el tamaño de la clave pública correspondiente a la utilizada para firmar el certificado de a) y los primeros 4 bytes de la que permiten verificarlo (puedes escribirlos en hexadecimal). [0,25 puntos]

Se ha utilizado una clave pública RSA de 2048 bits que empieza por E2 00 con un exponente 65537

- i) Escribe el nombre de la empresa y el nombre común de la autoridad de certificación raíz. [0,25 puntos]

DigiCert INC – DigiCert High Assurance EV Root CA

- j) ¿Qué certificados ha firmado la clave privada correspondiente a ese certificado? [1 punto]

La clave del certificado raíz ha firmado dos certificados, el suyo propio y el certificado de la autoridad intermedia.

- k) ¿Existe algún parámetro de esta cadena de certificación que pueda comprometer la seguridad de la misma?[0,75 puntos]

El certificado raíz está autofirmado con SHA1 que se sabe que es un algoritmo de hash no considerado seguro a día de hoy. Además, los tamaños de las claves para la autoridad de certificación son probablemente pequeños para lo que requeriríamos hoy en día (siendo mejor 4096 bits)

- l) Explica de forma breve el proceso por el que el ordenador confía en el certificado que le envía el servidor web de www.apple.com [1,5 punto]

El certificado de apple está firmado por un certificado que pertenece a una cadena de certificación de la que confía el navegador. Esto es porque existe una cadena de firmas que lleva al certificado raíz, en el que confía el propio navegador. El navegador confía en el certificado ya que viene pre-instalado en el mismo. Para poder pre-instalar el certificado en el navegador la AC ha tenido que pasar por una serie de controles y auditorias que aseguran que los procesos de seguridad llevados a cabo en la misma y los procesos de verificación de identidades cumplen unos estándares mínimos.

Ejercicio 2 [3 puntos]

Bob ha enviado a Alicia un documento con su correspondiente firma. Para calcular la firma, Bob ha utilizado RSA y una función hash que consiste en dividir el mensaje en bloques de 2 bytes y realizar una suma de todos los bloques módulo (2^9-1) . Dados los datos sobre el documento enviado, y las claves públicas de Bob y Alicia, responde a las siguientes preguntas:

- Documento (en hexadecimal): [B77B 1234]
- Firma (en hexadecimal): [14]
- Clave pública de Bob (ambos en decimal): {e=13 , n=65}
- Clave pública de Alicia(ambos en decimal): {e=13 , n=55}

- a) Verifica la firma realizada por Bob desde el punto de vista de Alicia. [2 puntos]

Los parámetros que se han utilizado para realizar los cálculos son los siguientes.

Para RSA. $P=5$ $q=13$. $N=65$ y $\phi(n)=48$. $E=13$ y $d=37$

Para verificar la firma en primer lugar calculamos el hash del documento. Para ello pasamos los números a decimal, los sumamos y los reducimos mod 2^9-1

$0xB77B = 46971$

$0x1234 = 4660$

$(0xb77b+0x1234) \bmod 2^9-1 = 20$ (en decimal)

Ese es el valor del hash. Para comprobar la firma lo que hacemos es descifrar el $0x14$ que es 20 en decimal (utilizando la clave pública de Bob).

$20^{13} \bmod 77 = 20$ por lo que la firma es correcta

a) Explica las implicaciones del resultado obtenido en el punto anterior [1 punto]

En el punto anterior se ha dado un caso especial de que el hash y la firma son iguales. Esto es debido a que las claves escogidas por bob son malas y no cifran realmente. Cuando Alicia comprueba la firma del mensaje y ve que es lo mismo que da la función hash, se debería de dar cuenta de que cualquiera va a poder firmar cualquier mensaje como Bob. Bastará con calcular el hash y poner ese hash como firma de Bob ya que siempre descifrá al mismo número